CloudDesk Technologies

Incident Response Plan

1. Authority, scope and response roles

SYNTHETIC / DEMO - document control

CD-IRP-001 | Version 1.0 (wording revision). Proposed effective date: 2026-10-22. Planned next review: 2027-10-22. These dates are proposals, not an approved schedule. Owner and incident coordinator: Engineering Lead. Accountable approver: CTO; approval not recorded. Review annually and after material incidents, exercises or changes.

Status and assumptions

CloudDesk Technologies is a fictional 75-person B2B SaaS vendor. This model-authored plan contains proposed SYNTHETIC / DEMO requirements, not operating facts. Review_status: requires_user_review. It provides no evidence of implemented controls, live reporting channels, completed response actions, notifications or successful restores. It makes no audit certification or legal compliance claim.

Purpose and scope

Use this plan to assess, contain and remove suspected threats to the confidentiality, integrity or availability of customer information and the hosted SaaS service, and to recover safely. It covers employees, contractors, service identities, cloud accounts, production and corporate systems, endpoints, vendors and backups. Use information_security_policy.pdf for service continuity and customer impact decisions. Follow encryption_key_management_policy.pdf for keys and encryption, and access_control_policy.pdf for access requirements; those policies remain authoritative in their areas.

Responsibilities and staffing

The CTO is accountable for material risk, resources, emergency authority and approval of external communications. The Engineering Lead coordinates triage, severity, assignments, the incident record and handovers. Platform Engineering and system owners investigate and recover systems as assigned. Managers handle personnel matters. Seek qualified legal/privacy advice and specialist help when needed; do not assume retained providers or a staffed legal team. Everyone must report suspicions. No dedicated or 24/7 SOC, on-call rota or guaranteed response time is assumed. Before adoption, the CTO must approve coverage, substitutes and contact routes.

Incident Response Plan

2. Reporting, classification and escalation

Proposed reporting routes

The proposed route is an access-restricted incident ticket and direct contact with the Engineering Lead through a verified internal directory. These are proposals, not live services or monitored addresses. If unavailable, contact the CTO or a designated substitute. If company accounts may be compromised, use a separately verified alternate contact method. Validate contacts, coverage and escalation paths before adoption. Report promptly when you discover a concern; do not wait for proof. Keep passwords, tokens and unnecessary customer data out of reports.

Event versus incident

An event is an observation, such as a failed login, alert or outage, that needs assessment. An incident is suspected or confirmed unauthorized access, disclosure, alteration, destructive activity or disruption that needs a coordinated response. The Engineering Lead records the classification and reasons, including false positives and routine faults. If significant harm is uncertain, handle the case as a provisional incident. A lack of confirmed exfiltration does not prove that no data was accessed.

Severity levels

SEV1 Critical: active widespread compromise, destructive cyber extortion, likely material customer data exposure or sustained loss of a critical service. Escalate directly to the CTO and start coordinating technical and continuity work immediately on recognition.

SEV2 High: credible privileged credential/key compromise, limited suspected customer exposure or significant contained disruption. Inform the CTO promptly and assess the need for specialist help.

SEV3 Moderate: an incident limited to one system, with no current evidence of privileged access or customer exposure. The Engineering Lead directs the response and informs the CTO if the scope grows.

SEV4 Low: a suspicious event or unsuccessful attempt with no identified impact. Record, assess and monitor it; record the reasons before closing it.

Reassessment and handover

Severity can change. Raise it for active spread, sensitive data access, tenant boundary failures, evidence tampering, key or backup compromise, uncertain containment, a growing outage or legal/contract notification triggers. Record discovery and awareness times, affected scope, confidence, owner, severity changes, next check and reasons for decisions. The coordinator sets update intervals for each case based on harm and responder availability; there is no fixed response guarantee. Escalate urgent reports that receive no acknowledgment through verified alternates. Hand over evidence, decisions and outstanding risks explicitly between responders.

3. Triage and evidence preservation

Initial assessment

Open a unique incident ID. Record the reporter, discovery time and timezone, symptoms, affected systems, tenants, information classes and service dependencies. Separate observed facts from hypotheses. Assess attacker access, persistence, possible exfiltration, business impact and ongoing harm. Identify evidence sources, including logs that may soon disappear. Use trusted administrative access and preserve relevant evidence before making changes where safe. Do not delay urgent containment just to collect evidence. Record any changes or lost evidence and explain why.

Collection and chain of custody

Assign an evidence custodian. For each item, record its ID, source asset/account, collection method and tool/version, collector, UTC acquisition time, original timezone, clock uncertainty and incident ID. Keep original exports read-only where supported. Calculate and record a SHA-256 hash at acquisition and verify copies. For every transfer, record sender, recipient, time in UTC, purpose, storage location and integrity check. Use working copies for analysis. Keep provenance and document gaps in the chain of custody. Hashes help track integrity; they do not by themselves prove authenticity or legal admissibility.

Restricted evidence handling

Collect relevant identity, cloud control-plane, SaaS audit, application and KMS records. Take snapshots when proportionate and authorized. Minimize personal/customer data and avoid copying plaintext secrets. Restrict access to assigned responders, encrypt stored evidence and transfers, and record access. Agree retention and holds using appropriate advice and applicable obligations before disposal. Preserve the encryption policy minimum 12-month retention for KMS audit logs; do not apply it automatically to all evidence. This plan does not claim existing log coverage or forensic readiness.

Investigation and decision log

Build a timeline that links evidence IDs to actions, indicators, affected identities, tenant scope and confidence. For significant response decisions, record alternatives, approval, expected harm and rollback. Check suspicious instructions through known contacts; do not run attacker-provided tools. Keep relevant vendor communications and request provider help through verified support routes. Check collection authority and customer agreements before accessing tenant content. Record inaccessible sources and unresolved scope rather than claiming certainty.

Incident Response Plan

4. Containment, eradication and safe recovery

Containment authority and tradeoffs

The Engineering Lead coordinates proportionate isolation of affected endpoints, workloads, sessions or network routes with system owners. Responders may take urgent reversible action to stop active harm without waiting for normal approvals. They must document the scope and inform the coordinator and CTO. The CTO authorizes material service shutdowns and decisions to accept residual risk. If unavailable, seek verified alternate approval and record any unavoidable emergency decision for review. Preserve evidence where safe, assess customer impact and recovery dependencies, and avoid destructive cleanup before necessary collection.

Cloud, SaaS and identity compromise

Check cloud IAM, federated identity, OAuth grants, API tokens, service accounts, automation, exposed storage, suspicious rules and cross-tenant paths. Revoke affected sessions and grants. Reset compromised credentials through trusted systems, rotate dependent secrets and remove unauthorized integrations. Look for persistence beyond password resets and coordinate with providers. Shared responsibility does not remove CloudDesk's investigation duties. Keep unique user accounts, MFA for administrative access and quarterly access reviews. Revoke terminated employee access within 24 hours. This is the outer termination limit; do not delay urgent compromise containment.

Key compromise and backup access

For suspected key compromise, immediately open an incident, revoke affected identity grants and disable compromised key versions where safe under CD-ENC-001. Replace compromised certificate private keys immediately. Create replacement keys and assess exposed data, historical re-encryption and backup recoverability. Rotation alone does not re-encrypt historical data. Keep restricted older key versions while retained data or backups need them. The CTO authorizes temporary emergency decrypt access, with logging and next-business-day review. Destruction requires Engineering Lead and CTO approval after retention and recovery checks. Never blindly delete keys to contain an incident.

Eradication and recovery gates

Find the root cause, remove persistence, patch or rebuild from trusted sources, and check configuration and replacement credentials. Keep backup-specific key grants separate from ordinary application access. Before restoring, assess backup integrity and the compromise window, scan in isolation, test authorized decrypt access, and validate data, tenant separation and critical service behavior. System owners propose phased reconnection, monitoring and rollback criteria. The Engineering Lead verifies containment. The CTO approves material residual risk and the return of critical service. Follow approved RTO/RPO when established; this plan guarantees no numerical targets. Reopen the investigation if indicators return.

Incident Response Plan

5. Extortion, communications and notification decisions

Cyber extortion decisions

Treat ransomware, destructive threats and data-theft extortion as potential SEV1 incidents. Keep demands and evidence, isolate affected paths, and protect clean backups and recovery credentials. Individual responders must not negotiate, pay, promise secrecy or contact attackers. The CTO coordinates decisions with qualified legal advice, appropriate leadership and relevant insurer/law-enforcement consultation where applicable. Assess safety, sanctions and other applicable restrictions, contractual duties, recoverability and alternatives. This plan pre-authorizes no payment. Payment or a decryption tool does not guarantee recovery, deletion or confidentiality. Record decisions and independently validate any proposed recovery tool in isolation.

Communication authorization

The Engineering Lead keeps a factual internal situation report covering known scope, uncertainty, actions proposed or taken, and the next review. The CTO authorizes external/customer communications with relevant legal/privacy advice and an assigned spokesperson. Responders must avoid speculation, attribution and unapproved statements. Verify recipients and use secure alternate routes if normal messaging is affected. Share sensitive indicators and personal data only with those who need them. Keep approved versions, recipients and delivery evidence. This plan records no actual communication or notification.

Customer and external notification assessment

Assess customer contracts, provider terms, applicable laws and affected jurisdictions case by case with qualified advice. Record when awareness arose, the decision owner, relevant duty/trigger, affected parties, required content, deadline and calculation basis, uncertainty and approval. There is no universal notification deadline in this plan. Do not wait for perfect attribution or a completed investigation when a duty requires earlier notice. Track changing facts and supplemental updates. Record the reasons for notification or non-notification. Consider regulators, affected individuals, customers, providers and law enforcement where applicable; every incident does not require every recipient.

Continuity and customer support

Coordinate service status, workarounds, restoration priorities and support responses with system owners and the CTO. Assess customer impacts and contractual recovery commitments without promising unverified restoration times. Check that only authorized recovery roles can access backups and that recovery does not reconnect compromised identities. Record disputed facts and decisions to defer recovery. Preserve required holds and evidence during communications and restoration.

Incident Response Plan

6. Closure, exercises and plan maintenance

Closure and lessons learned

The Engineering Lead proposes closure once scope and remaining uncertainty are documented, containment and recovery checks are recorded, notification decisions are tracked, and remaining risks have owners. The CTO reviews significant incidents and accepts material residual risk. Hold a blameless lessons-learned review after significant incidents. Cover the timeline, root cause, detection gaps, evidence quality, customer impact and response decisions. Assign corrective actions with owners, due dates, verification criteria and closure evidence. Add risks and overdue material actions to the risk register. Closure does not remove unresolved obligations or evidence holds.

Testing and awareness

Exercise incident scenarios at least annually alongside the information security policy annual continuity exercises, and after material changes. Include cloud credential/key compromise, SaaS tenant exposure, extortion, unavailable responders and customer notification decisions. Use fictional data and isolated environments. Record participants, assumptions, findings and corrective actions. Keep the encryption policy requirement to test a representative encrypted restore at least quarterly, checking integrity, authorized key access and outcome. Managers arrange security awareness at onboarding and annually, including incident reporting and phishing. This plan claims none of these exercises or training activities has been completed.

Records, exceptions and review

Keep incident records, evidence inventories, custody transfers, decision logs, approvals, notification assessments, recovery checks and follow-up records in an access-restricted repository. Follow approved retention and hold rules. The Engineering Lead reviews this plan annually and after significant incidents or changes, checks proposed contact routes and role substitutes, and submits revisions to the CTO. Emergency deviations need an incident record and CTO review by the next business day. Encryption exceptions still follow CD-ENC-001, including expiry within 90 days and monthly review. This plan claims no active exception or approved contact directory.

Adoption review checklist

Before adopting this plan, a human reviewer must confirm staffing, alternate contacts, response roles and authority. Check cloud and SaaS inventories, available logging, evidence access and backup/key dependencies. Review customer contracts and obtain jurisdiction-specific advice. Check consistency with the three related policies. Record reviewer feedback and CTO approval. Current approval_status: not_recorded; review_status: requires_user_review. This is a proposed plan, not an incident history, evidence of operating controls or certification.